

Segurança e Boas Práticas em IA

CHEAT SHEET #03

Cheat Sheet de Ameaças & Mitigações — SECOMP 2026

Principais Vulnerabilidades em Sistemas de IA

Ameaça	Descrição	Estratégia de Mitigação
Prompt Injection	Injeção de instruções maliciosas pelo usuário para alterar o comportamento do sistema.	Sanitização rigorosa de inputs e separação estrita entre System e User Prompt.
Jailbreak	Técnicas de engenharia social para burlar os filtros de segurança e ética do LLM.	Implementação de Guardrails na entrada e na saída do modelo.
Data Leakage	Exposição indevida de dados sigilosos armazenados na base RAG.	Controle de acesso granular (RBAC) na camada do Vector DB.
Excessive Agency	Agentes com autonomia/permisões além do estritamente necessário.	Princípio do Menor Privilégio e aprovação humana (Human-in-the-loop).

Checklist de Produção (Go-Live)

- [] Auditoria de Logs: Rastreamento completo de todas as ferramentas e rotas acionadas por agentes.
- [] Criptografia: Dados em trânsito (TLS) e em descanso (AES-256) no Vector DB e variáveis de ambiente.
- [] Princípio do Menor Privilégio: Servidores MCP restritos a operações estritamente necessárias.
- [] Conformidade LGPD: Coleta mínima de dados pessoais e política clara de retenção de histórico.